

challenge, particularly when MSSPs have access to confidential or sensitive information that requires increased protection. In addition, FIs can have high levels of risk exposure in the event that an MSSP cannot comply with service level agreements.

As with all outsourcing arrangements FI management can outsource the daily responsibilities and expertise; however, they cannot outsource accountability.

MSSP Engagement Criteria

MSSP: ENGAGEMENT CRITERIA

SLA - Service level agreement

RFI - Request for information

RFP - Request for proposal

* Contract Provisions for consideration

Criteria	Description	Phase	Information/Expectations
Service Availability	Due to the nature of managed security services, it is critical that the service be operational 24x7 to the fullest extent practicable. While an outage to a core banking system (e.g., teller, loan processing, etc.) may be manageable, a momentary failure of a FI's managed security environment could have disastrous consequences.	SLA* RFI/RFP/SLA SLA* SLA RFP/SLA*	Specify recovery time when a service outage occurs MTTR (Mean Time to Recovery) Identify expectations of percentage of system uptime Notification of any planned outages Defined system performance reports Schedule for applicable credits and compensation
Incident Response and Notification	Timely notification and classification of incidents is critical for most MSSP engagements. The severity of the incident and its potential impact must be identified and communicated to appropriate staff. Plans should be comprehensive and customized to the FI in order to minimize the impact of the breach.	SLA RFP/SLA RFP/SLA RFI/RFP/SLA* RFP/SLA* RFP/SLA	Key staff and backups identified with 24x7 availability Defined severity levels with appropriate escalation requirements Maximum timeframe for communicating new problems and action items Review MSSP incident response plan which should specify how incidents will be handled and by whom. Table top testing is vital to ensure MSSP and FI understand their roles in an actual event Consider MSSP forensic analysis procedures
State/Federal Compliance	Existing state and federal law and regulations	RFP*	Ensure MSSP complies with applicable notification requirements for data security/privacy

Criteria	Description	Phase	Information/Expectations
Staffing	MSSPs provide specialized services performed by IT professionals that must have the expertise necessary to identify and respond to current IT security issues.	RFP/SLA	Identification of staff professional certifications (e.g., CISSP, CISM, etc.)
		RFP/SLA	Procedures for background checks and hiring criteria
		RFI/RFP	Describe process for monitoring Security Operations Center (SOC) personnel
		RFI/RFP	Describe procedures for initial and ongoing staff training.
		RFI/RFP	Provide profile of staffing resources (e.g., experience, number of employees, etc.)
Third-Parties and Subcontractors	FIs must protect customer information, sensitive corporate data, and maintain high availability of services regardless of outsourced relationships. This obligation extends to any third parties utilized to deliver their services.	RFI/RFP*	Identify 3rd parties that may be used and describe roles and oversight.
		RFP*	Notification/approval of significant subcontractors

Handling Sensitive Data	In many engagements, MSSPs may have access to non-public customer data and sensitive information about the FI and its operating environment. Depending on the relationship, the FI may no longer have direct control over the data.	SLA* SLA RFI/RFP/SLA RFP/SLA*	Procedures for restricting use of any sensitive data whether in-transit or at rest Procedures for disclosing the loss or unauthorized access to sensitive data Primary location of data processing and storage (US based) Secure storage, retention, and destruction of data should be clearly defined
Service Scalability	The ability to provide scalable services on a near real-time basis is often one of the key factors considered by FIs in choosing an MSSP.	SLA SLA	Regular reporting of capacity-related statistics such as bandwidth utilization, storage used, and percent of system capacity used. Consideration of anticipated rates of capacity growth, storage needs, and seasonal or promotional spikes

Criteria	Description	Phase	Information/Expectations
Disaster Recovery	In the event the MSSP is subject to a disruptive event, it is critical that services to the FIs remain uninterrupted to the fullest extent practicable.	RFP/SLA*	Access to MSSPs' business continuity plan and testing results
		RFP/SLA*	Standards for Mean Time to Recovery (MTTR)
Customer Support	The breadth of issues that may arise in an MSSP engagement may require 24x7 live customer support.	RFP/SLA	Customer support Guaranteed Response Time (GTR)
Hardware Replacement*	Some MSSP services involve installation of a proprietary hardware device at the FI.	SLA*	Minimum time for delivery of replacement device
		SLA	Backup device
		RFP/SLA	Established procedures for onsite support
Training/Education	FIs may not have the staff expertise to understand the information provided by MSSP specialized management and reporting tools.	RFP/SLA	Classroom/onsite training
		RFP/SLA	Web-based tutorials
		RFP/SLA	Consulting services

Technology	MSSPs utilize specialized technology and information resources that are critical to the service offerings.	RFI/RFP SLA RFP RFI/RFP/SLA	Describe methodology used for collecting, reporting, and analyzing threats, vulnerabilities, or possible attacks. Proprietary technology required Changes required to existing network architecture, configuration or systems SDLC procedures for services delivered
Due Diligence (e.g., onsite visits, audits, financial reviews)	MSSPs have evolved rapidly over the past 10 years from the entrepreneurial "garage business" to formal offerings and facilities. Onsite visits and audit reviews throughout the lifecycle can provide a valuable window to ensure services are offered in a safe and secure manner.	RFI/RFP/SLA RFP/SLA RFP*	What recognized audit reports are available for review (e.g., SAS70, SSAE 16, etc.) Provision for pre-engagement and periodic site visits. Access to annual financial statements

MSSP Examination Procedures

EXAMINATION PROCEDURES

NOTE: This appendix includes all of the steps in Appendix A, plus unique ones for MSSP's.

EXAMINATION OBJECTIVE: Assess the effectiveness of the institution's risk management process as it relates to the outsourcing of information systems and

technology and security services, and the heightened risks specific to the outsourcing of security services to a Managed Security Services Provider (MSSP).

Tier I and Tier II Objectives and Examination Procedures are intended to be a tool set examiners will use when selecting examination procedures for their particular examinations. Examiners should use these procedures as necessary to support examination objectives.

Tier I Objectives and Procedures relate to the institution's implementation of a process for identifying and managing risks related to outsourcing functions to an MSSP.

Tier II Objectives and Procedures provide additional validation and testing techniques, as warranted by risk, to verify the effectiveness of the institution's process on individual MSSP contracts.

TIER I OBJECTIVES AND PROCEDURES

Objective 1: Determine the appropriate scope for the examination.

1. Review past reports for weaknesses involving outsourcing. Consider:

- Regulatory reports of examination of the institution and service provider(s); and
- Internal and external audit reports of the institution and service provider(s).

2. Assess management's response to issues raised since the last examination.

Consider:

- Resolution of root causes rather than just specific issues; and
- Existence of any outstanding issues.

3. Interview management and review institution information to identify:

- Current outsourcing relationships and changes to those relationships since the last examination. Also identify: Material service provider subcontractors,

Also identify:

- o Material service provider subcontractors,
 - o Affiliated service providers,
 - o Foreign-based third party providers;
-
- Current transaction volume for each function outsourced;
-
-
- Material problems experienced with the service provided;
-
-
- Service providers with significant financial or control-related weaknesses;
and
 - When applicable, whether the primary regulator has been notified of the outsourcing relationship as required by the Bank Service Company Act or Home Owners' Loan Act.

Objective 2: Evaluate the quantity of risk present from the institution's outsourcing arrangements.

1. Assess the level of risk present in outsourcing arrangements. Consider risks pertaining to or associated with:

- Functions outsourced;
-
-
-
-
-
-
-
-
-
-
- Service providers, including where appropriate, unique risks inherent in foreign-based service provider arrangements;
-
-
-
-
-
-
-
-
-
-
- Technologies used;

- Staff qualifications;
- The MSSP's risk assessment program and whether it includes business process, information security infrastructure, related risk assessments, etc.; and
- The frequency of MSSP risk assessments

Objective 3: Evaluate the quality of risk management.

1. Evaluate the outsourcing process for appropriateness, given the size and complexity of the institution. The following elements are particularly important;

- Institution's evaluation of service providers consistent with scope;
-
- Requirements for ongoing monitoring; and
- Determination of whether the Request for Information (RFI) document outlines the security functions the financial institution (FI) intends to incorporate into the contract with an MSSP.

2. Evaluate the requirements definition process.

- Ascertain that all stakeholders are involved; the requirements are developed to allow for subsequent use in Request For Proposals (RFPs), contracts, and monitoring; and actions are required to be documented; and
- Ascertain that the requirements definition is sufficiently complete to support the future control efforts of service provider selection, contract preparation, and monitoring.

3. Evaluate the service provider selection process to determine if:

- An RFI/RFP was completed;

- The FI included RFI/RFP elements appropriate to level of risk;
- The RFP adequately encapsulates the institution's requirements and that elements included in the requirements definition are complete and sufficiently detailed to support subsequent RFP development, contract formulation, and monitoring;
- Any differences between the RFP and the submission of the selected service provider are appropriately evaluated, and that the institution takes appropriate actions to mitigate risks arising from requirements not being met; and
- Due diligence requirements encompass all material aspects of the service provider relationship, such as the provider's financial condition, reputation (e.g., reference checks), controls, key personnel, disaster recovery plans and tests, insurance, communications capabilities and use of subcontractors.

4. Evaluate the process for entering into a contract with a service provider.

Consider whether:

- The contract contains adequate and measurable service level agreements;
- Allowed pricing methods adversely affect the institution's safety and soundness, including the reasonableness of future price changes;
- The rights and responsibilities of both parties are sufficiently detailed;
- Required contract clauses address significant issues, such as financial and control reporting, right to audit, ownership of data and programs, confidentiality, subcontractors, continuity of service, etc.;
- Legal counsel reviewed the contract and legal issues were satisfactorily resolved;
- Contract inducement concerns are adequately addressed; and